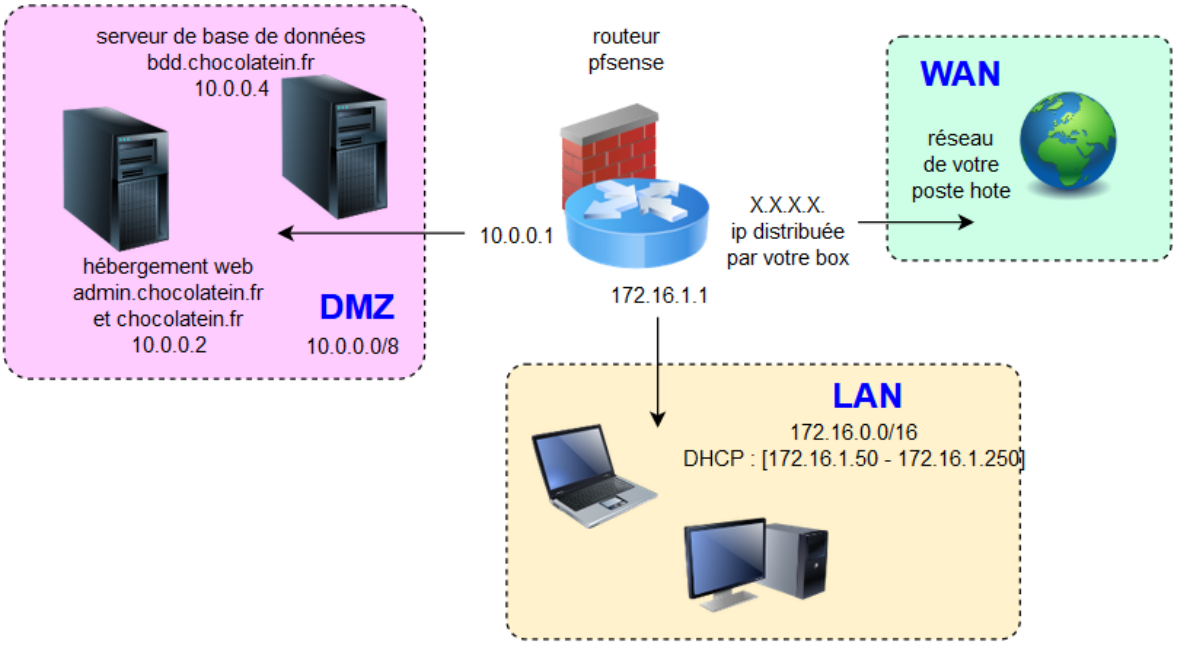
Dossier technique infrastructure client

Ce document détaille le contenu de la plateforme « plateforme-chocolatein.ova » qui est un environnement de test conçu pour reproduire l'infrastructure des sites à auditer (l'hébergement chez le prestataire externe est simulé par le reseau interne DMZ) et le réseau depuis lequel les tests seront effectués (réseau du prestataire B3-SIO Audit est simulé par le réseau interne LAN).
Il indique également les comptes utilisateurs fournis par le client pour opérer les tests en boite grise (grey-box)

Table des matières

Dossier technique infrastructure client 1
Schéma réseau synthétique 1
Procédure d'installation de l'environnement du client 2
Description détaillée de la plateforme importée 2
routeur-pfSense 3
Serveur de base de données sbdd-chocolatein 3
Serveur web sweb-chocolatein 4
Comptes d'utilisateurs fournis par le client 4

Schéma réseau synthétique



Procédure d'installation de l'environnement du client

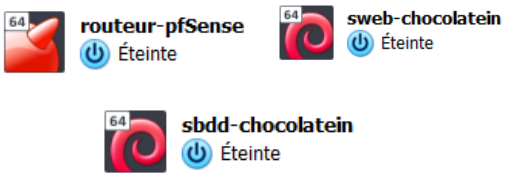
L'environnement à auditer concerne 2 hébergements web et la base de données des sites chocolatein (site vitrine (front-office) et site d'administration (back-office).

L'environnement de test conçu par l'équipe technique contient plusieurs machines virtuelles Virtual Box rassemblées dans l'archive *plateforme-chocolatein ova*.qui représente :

- Le réseau depuis lequel le test d'intrusion sera effectué (LAN sur le schéma) ;
- Le réseau dans lequel les serveurs web et bdd à pentester sont hébergés (DMZ sur le schéma) ;
- L'accès à internet au besoin via votre propre réseau.

Une fois importée dans virtual box, vous devez voir apparaitre les 3 machines suivantes. Chacune de ces machines doit être déjà configurée correctement et contient un texte de description dont les principaux éléments sont détaillés dans la rubrique suivante :

- routeur-pfSense :
  - système : 1Gio de Ram, 1 processeur,
  - 3 interfaces réseau activées :
    - Adapter1 en accès NAT,
    - Adapter2 en réseau interne « LAN »,
    - Adapter3 en réseau interne « DMZ »,



- sbdd-chocolatein :
  - système : 1Gio de Ram, 1 processeur,
  - 1 interface réseau activée : Adapter1 en réseau interne « DMZ »
- sweb-chocolatein
  - système : 1Gio de Ram, 1 processeur,
  - 1 interface réseau activée : Adapter1 en réseau interne « DMZ »

Si besoin, vous allez pouvoir ajuster les capacités en Ram et en processeur alloués en fonction des autres machines qui tourneront pour votre labo (attention, il faudra également ajouter votre machine Kali dans ces ressources)

Attention : Il est nécessaire de vérifier que la carte réseau sélectionnée dans les paramètres de la carte réseau adapter1 de la VM pfsense correspond bien à une carte réseau de votre machine hôte accédant à internet.

Description détaillée de la plateforme importée

Cette rubrique indique les caractéristiques techniques des différentes machines de la plateforme de test qui a été conçue pour correspondre le plus fidèlement possible aux servers de l'hébergeur.

routeur-pfSense

La machine virtuelle routeur-pfSense est un routeur/pare-feu open source, basé sur le système d'exploitation FreeBSD qui permet également d'exécuter plusieurs services (NAT, DNS, DHCP, portail captif, …). Il simule l'accès entre les réseaux du pentesteur, de l'hébergeur et le net.

Dans cette infrastructure, son rôle est d'interconnecter les 3 réseaux LAN, WAN et DMZ

- Le reseau LAN configuré en 172.16.0.0 /16 qui simule les machines présentes chez le client (c'est dans ce réseau que votre machine de tests d'intrusion devra être ajoutée). La passerelle pour ce réseau est **l'interface LAN 172.16.1.1** du routeur (carte réseau configurée sur le réseau privé LAN).
- Le réseau DMZ configuré en 10.0.0.0 /8 qui simule les serveurs web et BDD hébergés chez un fournisseur. La passerelle pour ce réseau est **l'interface DMZ 10.0.0.1** du routeur (carte réseau configurée sur le réseau privé DMZ).
- Le réseau WAN qui représente l'accès à internet et qui est configuré derrière **l'interface WAN configurée en DHCP** (récupère une adresse dynamique donnée par votre box)

Il distribue également des adresses DHCP sur les réseaux LAN et DMZ avec les plages suivantes :

- DHCP sur LAN : adresses de 172.16.1.50 à 172.16.1.250
- DHCP sur DMZ : adresses de 10.0.1.1 à 10.0.1.255

Enfin il résout les demandes DNS adressées depuis les réseaux LAN et DMZ :

Host	Parent domain of host	IP to return for host
admin	chocolatein.fr	10.0.0.2
bdd	chocolatein.fr	10.0.0.4
www	chocolatein.fr	10.0.0.2
web	chocolatein.fr	Alias for www.chocolatein.fr
	chocolatein.fr	Alias for www.chocolatein.fr

Le routeur s'administre depuis une interface web accessible depuis une machine du réseau LAN sur l'url http://172.16.1.1 avec le compte admin / adminPfsense
Normalement vous n'avez pas besoin de toucher à sa configuration.

Serveur de base de données sbdd-chocolatein

La machine virtuelle sbdd-chocolatein est un serveur Debian 10 exécutant mariaDB et hébergeant la base de données de Chocolatein dans le réseau DMZ simulant l'hébergeur. Il contient également un serveur apache permettant d'interroger les bases de données via le client web phpmyadmin.

Cette machine est accessible depuis les réseaux LAN et DMZ depuis l'IP 10.0.0.4 et le nom bdd.chocolatein.fr.
La consultation des bases de données peut se faire via le client phpmyadmin à travers l'url ou http://bdd.chocolatein.fr:9000 (ou http://10.0.0.4:9000)
L'utilisateur de la base chocolatein est « userchoc » avec le mot de passe « p@ssCh0c »

Le système du serveur est debian 10 et les paquets suivants sont installés : php 7.3.19 , 10.3.27-MariaDB , apache version 2.4.38

Les utilisateurs systèmes sont :

- sio:sio (utilisateur à privilégier pour travailler)
- root:root

Serveur web sweb-chocolatein

La machine virtuelle sweb-chocolatein est un serveur Debian 10 executant un serveur Apache multisite hébergeant les applications site vitrine et site d'administration de Chocolatein dans le réseau DMZ simulant l'hébergeur.

Les 2 sites sont consultables depuis les machines des réseaux LAN ou DMZ :

- Le site vitrine via http://chocolatein.fr , http://web.chocolatein.fr et http://www.chocolatein.fr .
- Le site d'administration via http://admin.chocolatein.fr.

L'accès en ssh à cette machine est possible sur l'hôte http://chocolatein.fr par l'utilisateur « userchoc » avec le mot de passe « p@ssCh0c ».

Les fichiers des deux sites web appartiennent à cet utilisateur et sont

- site vitrine : dossier /var/www/html
- site d'administration : dossier /var/www/site2

Le système du serveur est debian 10 et les paquets suivants sont installés : php 7.3.19 , apache version 2.4.38, OpenSSH_7.9p1 Debian-10+deb10u2, OpenSSL 1.1.1d

Les utilisateurs systèmes sont :

- sio:sio (pas d'accès en ssh, accès uniquement depuis le serveur)
- root:root (pas d'accès en ssh, accès uniquement depuis le serveur)
- userchoc:p@ssCh0c (utilisateur pour les connexion ssh)

Comptes d'utilisateurs fournis par le client

Pour les besoins du pentest en boite grise (grey-box), le client a fourni à B3-SIO Audit des comptes utilisateurs avec des rôles différents sur les différentes applications à tester.

Pour le site chocolatein.fr : Il n'y a pas d'accès privé sur ce site, les visiteurs n'ont pas besoin de s'authentifier

Pour le site admin.chocolatein.fr : le client a fourni 3 comptes avec des rôles différents :

- Le rôle Editeur peut mettre à jour le catalogue et les actualités
- Le rôle Modérateur peut mettre à jour le catalogue et traiter les messages
- Le rôle Administrateur peut mettre à jour le catalogue, traiter les messages et gérer les comptes utilisateurs

login	Mot de passe	role
bob@chocolatein.fr	mdp	Editeur
tab@chocolatein.fr	mdp	Administrateur
jose@chocolatein.fr	mdp	Modérateur

Pour le site bdd.chocolatein.fr : le client a fourni les identifiants du compte utilisé pour établir la connexion dans le code des applications :

login	Mot de passe
userchoc	p@ssCh0c